

# PHP MySQLi Debugging Task - Issues and Corrected Version

This task tests understanding of legacy PHP security issues, SQL injection prevention, validation, error handling, and secure database interaction using MySQLi prepared statements.

## Original Buggy Code

```
<?php
$conn = mysqli_connect("localhost", "root", "", "test");

$id = $_GET['id'];

$query = "SELECT * FROM users WHERE id = $id";

$result = mysqli_query($conn, $query);

if($result){
    while($row = mysqli_fetch_assoc($result)){
        echo $row['name'];
    }
}else{
    echo "Query failed";
}

mysqli_close($conn);
?>
```

## Issues Identified

| Issue                        | Explanation                                         |
|------------------------------|-----------------------------------------------------|
| SQL Injection                | User input is directly inserted into SQL query.     |
| No Input Validation          | The id parameter accepts any value without checks.  |
| No Connection Error Handling | Database connection failure is ignored.             |
| Poor Error Handling          | Generic error messages are not useful.              |
| SELECT * Usage               | Fetches unnecessary columns from database.          |
| Undefined GET Parameter      | Code breaks if id is missing from URL.              |
| No Empty Result Handling     | No message shown when user not found.               |
| XSS Risk                     | Output is not escaped before displaying in browser. |

## Corrected Secure Version

```
<?php

$conn = mysqli_connect("localhost", "root", "", "test");

// Check connection
if (!$conn) {
    die("Database connection failed: " . mysqli_connect_error());
}

// Validate ID
if (!isset($_GET['id']) || !filter_var($_GET['id'], FILTER_VALIDATE_INT)) {
    die("Invalid user ID");
}
$id = (int) $_GET['id'];
```

```

// Prepared statement
$stmt = mysqli_prepare($conn, "SELECT name FROM users WHERE id = ?");

if (!$stmt) {
    die("Prepare failed: " . mysqli_error($conn));
}

// Bind parameter
mysqli_stmt_bind_param($stmt, "i", $id);

// Execute query
if (!mysqli_stmt_execute($stmt)) {
    die("Execution failed: " . mysqli_stmt_error($stmt));
}

// Get result
$result = mysqli_stmt_get_result($stmt);

// Check if user exists
if (mysqli_num_rows($result) > 0) {
    while ($row = mysqli_fetch_assoc($result)) {
        echo htmlspecialchars($row['name']);
    }
} else {
    echo "No user found";
}

// Close resources
mysqli_stmt_close($stmt);
mysqli_close($conn);

?>

```

## Summary

The corrected version prevents SQL injection using prepared statements, validates input properly, handles database errors safely, prevents XSS attacks using `htmlspecialchars()`, and optimizes the query by selecting only required columns.